

Halmstad University

***Cyber Security Analyst Program / Penetration Testing and
Ethical Hacking 15.0 DI4027 vt 2026***

Evaluating the Efficacy of Cisco Foundation-Sec-8B: A Comparative Study Against General-Purpose LLMs (Gemni) in Cybersecurity Incident Analysis

Prepared By (Creators / Students):

**Vahid Lalipourdizaji, Morteza Nosrati, Sreeya Arlagadda and Linto
Chavarupara Devesia (Group 5)**

Supervised By (Teachers):

Olga Torstensson & Jonny Svensson

Academic Term: Spring 2026

Date of Submission: 2026-05-27

Table of Contents

Section	Title	Page
1	Introduction	4
1.1	Scenario and Project Motivation	4
1.2	Ethical Issues	4-5
1.3	Research Question	6
2	Project Objectives, Goals, and Method	6
2.1	Objectives and Limitations	6
2.2	Main Goals	6
2.3	Possible Methods	6
2.4	Our Chosen Method: Comparative Benchmarking Framework	7
2.4.1	What we know, and what we need to know	7
2.4.2	How to apply the comparative benchmarking framework	7
2.5	Limitations	8
3	Theoretical Background	8
3.1	What is Artificial Intelligence (AI) and its background	8
3.1.1	AI Types	8
3.1.2	AI Basics and Techniques	9
3.1.3	AI Applications	9
3.2	AI and Cybersecurity	9
3.2.1	Key aspects of this relationship	9
3.3	Barriers to using AI in Cybersecurity	10
3.3.1	Data Privacy Concerns	10
3.3.2	The 'False Positive' Problem	10
3.3.3	Ethical Issues and Bias	10
3.3.4	Reliance on High-Quality Data	10
3.4	Hallucination and Generalization in Cybersecurity Analysis	10
3.4.1	What are Hallucination and Generalization	10
3.4.2	The effect of Hallucination and Generalization in Cybersecurity Analysis	11

3.5	Cisco Foundation-Sec-8B	11
3.5.1	Key Applications of Cisco Foundation-Sec-8B	12
3.6	Comparing Cisco Foundation-Sec-8B with other Models	12
3.6.1	Accuracy and Performance	12
3.6.2	Privacy	13
3.6.3	Cost and Efficiency	13
3.6.4	Ethical Issues and Bias	14
3.7	Understanding CVE and CWE	14
3.7.1	Common Vulnerabilities and Exposures (CVE)	115
3.7.2	Common Weakness Enumeration (CWE)	15
3.7.3	The Relationship Between CVE and CWE	15
4	Results and Analysis	15
4.1	Design and Development	15
4.2	Testing and Validation	25
4.2.1	CWE Performance	25
4.2.2	Hallucinations and Reasoning	25
4.2.3	Mitigation Recommendations	26
5	Conclusion	26
5.1	Accuracy and Performance	26
5.2	The Problem of Hallucination	27
5.3	Practical Recommendations	27
5.4	Final Verdict	27
6	Reference	27
7	Attachments	28

1. Introduction

1.1. Scenario and Project Motivation

Today, AI is one of the most important tools used in daily work. In cybersecurity, many companies use AI to analyze security threats. They often share "Indicators of Compromise" (IOCs) and system logs with AI tools like "ChatGPT" or "Gemini" to understand the attacks they are facing. 1

However, there is a major privacy issue. These general AI tools were not built to keep data private. When a user types sensitive information into them, that data is sent to a main server for analysis and AI training. In high-security areas like the "military", "government", or "healthcare", sharing this kind of secret data is strictly forbidden because it could lead to a data leak. 2

To solve this, Cisco created a new model called "Foundation-Sec-8B." This model was built specifically for cybersecurity. It is designed to help analysts privately review logs and security data, ensuring that the information remains secure and does not reach a public server. 3

1.2. Ethical Issues

The findings of this comparative study raise several critical ethical dilemmas that organizations, researchers, and cybersecurity practitioners must navigate when deploying AI-driven security tools.

1.2.1. The Ethics of the Security-vs.-Privacy Trade-Off

The most significant ethical conflict highlighted by this research is the tension between data privacy and operational safety. Implementing the Cisco Foundation-Sec-8B model offers clear privacy advantages, as data remains localized. However, given its 50% accuracy in CWE mapping and its reliance on pre-2021 data, recommending this model solely on privacy metrics poses an ethical hazard.

Choosing a significantly weaker security tool to protect data privacy can inadvertently leave an organization vulnerable to modern cyber threats (such as the 2026 vulnerabilities identified by Gemini). This creates a false sense of security, potentially exposing stakeholder data, employee

records, and critical infrastructure to successful breaches. Therefore, organizations face an ethical obligation to balance the right to data privacy against the duty to provide robust, effective protection against cyberattacks.

1.2.2. Misdirection and Accountability in Automated Incident Response

As shown in Section 5.2, the Cisco model exhibited severe hallucinations, such as falsely mapping a "Web Pros" attack to a "Pulse Secure VPN." In a real-world security operations center (SOC), such hallucinations are not just minor errors—they are active misdirections.

- Alert Fatigue and Burnout: Forcing human analysts to chase false leads wastes valuable time during an active breach, contributing to cognitive overload and alert fatigue.
- The Accountability Gap: If an organization relies on an AI that misleads analysts, leading to a major unmitigated breach, where does the ethical culpability lie? Relying on a model known for severe hallucinations raises questions about corporate negligence if that model is deployed as a primary line of defense.

1.2.3. Responsible Disclosure and Vendor Accountability

By documenting the specific limitations, outdated training data, and tendency toward hallucinations of the Cisco Foundation-Sec-8B model, this paper highlights product deficiencies that could affect current users. Ethically, the goal of this research is not to damage a vendor's reputation, but to foster transparency and improve industry standards. Researchers have a responsibility to communicate these findings in a way that encourages vendors to update their knowledge bases (moving past 2021 data) and refine their training methodologies, ensuring that "security-specialized" AI tools actually meet the rigorous demands of modern threat landscapes.

1.2.4. Ethical Use of General-Purpose AI in Security

Conversely, recommending Gemini as the more effective tool introduces its own ethical guardrails. Because Gemini is a public, general-purpose AI, uploading real-world incident logs or proprietary code to its servers risks exposing data or leading to compliance violations (e.g., GDPR, HIPAA). Therefore, this paper ethically conditions its recommendation of Gemini on the strict implementation of data masking, anonymization, and enterprise-grade privacy guardrails to ensure that achieving higher security accuracy does not come at the cost of sensitive organizational data leakage.

1.3. Research Question

The goal of this research is to determine whether a specialized security AI is actually better than a general-purpose AI. We will answer this question:

"How accurate is the Cisco Foundation-Sec-8B at analyzing the cybersecurity incident compared to general-purpose AI like Gemini 2.0?"

We want to find out whether Cisco's model is better at staying secure and accurate or whether it has limitations users should know about.

2. Project Objectives, Goals, and Method

2.1. Objectives and Limitations

The main goal of this project is to evaluate the performance of the Cisco Foundation-Sec-8B model in a real-world company setting. We want to determine whether we can honestly recommend this tool to an organization that cares about security.

We also want to understand:

1. How does this specific security AI compare to powerful, general AIs like Gemini?
2. What are its main weaknesses or "limitations"?

2.2. Main Goals

- **Compare Performance:** Measure if a smaller, private AI (Cisco) is as smart as a giant, public AI (Gemini).
- **Provide Advice:** Decide whether the privacy benefits of the Cisco model outweigh any performance loss.

2.3. Possible Methods

When researchers test something, they usually choose between two methods:

- **Qualitative Method:** This is about feelings and descriptions. It looks at "how" and "why" things happen, but doesn't rely on many numbers.
- **Quantitative Method:** This is about numbers and math. It measures exactly how many times something succeeds or fails. It is objective and keeps things fair.

2.4. Our Chosen Method: Comparative Benchmarking Framework

We chose the Comparative Benchmarking Framework, which is a systematic method for evaluating organizational performance by comparing it with others, enabling businesses to improve operations, make informed decisions, and achieve sustainable growth. This framework combines qualitative and quantitative methods. 4

2.4.1 What we know, and what we need to know

We used the CISA website 5, which is the U.S. government's central hub for national cybersecurity and infrastructure protection. It provides real-time threat alerts, a catalog of known software vulnerabilities, and reporting portals for cyber incidents. We downloaded the latest dataset on CVE (Common Vulnerabilities and Exposures), which provides a structured ground truth with specific CVE IDs, brief explanations, mitigation strategies, and associated CWEs (Common Weakness Enumeration).

To evaluate the performance of various AI models, we require a robust benchmarking framework to measure the accuracy of their outputs against this reference data. We propose a comparative benchmarking framework that integrates both qualitative and quantitative methods. This approach allows us to verify the precision of technical identifiers (CVE/CWE) while simultaneously assessing the practical viability of the proposed mitigation methods for end users.

2.4.2. How to apply the comparative benchmarking framework

To ensure consistency, we utilized an identical prompt for both Gemini and Cisco AI:

"Read this attack description, map it to CVE and CWE, and provide mitigation strategies."

This prompt was paired with the specific descriptions provided in our dataset. We conducted this test across 10 distinct CVEs, collecting the responses from both models to evaluate their

accuracy against our established ground truth. The complete results of this comparative analysis are provided in the appendix at the end of this paper.

2.5. Limitations

It is important to clarify that this research focuses on the behavioral analysis of AI models rather than their internal architecture, as we are not AI developers. Consequently, our methodology evaluates model outputs rather than modifying internal code.

While we believe this comparative approach is the most effective for our objectives, we recognize that it is a novel method and may be subject to different interpretations regarding fairness.

Furthermore, this study does not assess the internal privacy protocols of the models; we have relied solely on the manufacturers' official documentation.

Finally, due to time and technical constraints, Retrieval-Augmented Generation (RAG) was not implemented. We acknowledge that the absence of RAG may influence the models' performance compared to optimized production environments.

3. Theoretical background.

3.1. Artificial Intelligence: Definition and Historical Context

Artificial Intelligence (AI) is a field of science and technology dedicated to replicating human intelligence and cognitive abilities in computer systems. Its primary goal is to make machines smarter and more effective by equipping them with human-like capabilities such as understanding, reasoning, and decision-making. The term Artificial Intelligence was first used by John McCarthy in 1956 during a conference at Dartmouth University. 6

3.1.1. AI Types

We have two types of AI: Weak and Strong.

Weak AI refers to systems designed to perform specific, restricted tasks, such as voice assistants, text recognition, or game-playing programs. On the other hand, Strong AI refers to systems that aim for a general level of human-like intelligence or higher, capable of solving complex problems and performing creative tasks across different fields. 6

3.1.2. AI Basics and Techniques

The foundation of AI lies in areas such as expert systems, robotics, natural language processing (NLP), computer vision, and speech recognition. Its technical implementation often involves machine learning (ML), deep learning (DL), and artificial neural networks (ANN). 6

3.1.3. AI Applications

AI is used effectively in numerous sectors today, including healthcare, education, industry, and defense, to increase efficiency, automate repetitive tasks, and analyze large datasets to predict future trends. 6

3.2. AI and Cybersecurity

The relationship between AI and cybersecurity is marked by a paradigm shift from reactive, signature-based defenses to proactive, adaptive, and automated security measures. As cyber threats grow in volume and sophistication, traditional defenses are often insufficient, making AI an essential tool for building resilient defenses. 2

3.2.1. Key aspects of this relationship include:

- Enhanced Threat Detection: AI can analyze vast amounts of data at high speeds to identify patterns and anomalies, such as zero-day vulnerabilities or advanced persistent threats, that are difficult for human analysts to spot in real time. 2
- Automated Incident Response: AI-driven systems can automatically mitigate risks by isolating compromised systems, blocking suspicious network traffic, and initiating remediation protocols, significantly reducing the time required to address incidents. 2
- Predictive Capabilities: Through predictive analytics, AI identifies trends in historical data to forecast potential future attacks, allowing organizations to allocate resources more effectively and improve their overall security posture. 2

- Continuous Learning: Unlike traditional static rules, AI systems continuously learn and adapt from new data and emerging threats, enhancing the robustness of security measures over time. 2
- Strategic Optimization: By automating repetitive tasks like log analysis and network monitoring, AI frees up human security professionals to focus on strategic tasks such as threat hunting and complex incident investigation. 2

3.3. Barriers to using AI in cybersecurity

While the integration of AI into cybersecurity offers significant benefits, several critical barriers and limitations must be addressed for it to be effective and secure:

3.3.1. Data Privacy Concerns:

This is one of the most significant hurdles. AI algorithms require large volumes of sensitive data, including user behavior and network activity, to function. Organizations must navigate strict regulations such as the GDPR and balance security monitoring with respect for individual privacy rights to avoid legal penalties and loss of trust. 2

3.3.2. The "False Positive" Problem:

AI systems are not perfect and frequently generate false alarms. An excessive number of false positives leads to "alert fatigue," where security personnel become desensitized to notifications, potentially causing them to overlook genuine, high-priority threats. 2

3.3.3. Ethical Issues and Bias:

AI systems can inherit biases from the datasets used to train them. If a dataset over-represents certain behaviors or demographics, the AI may disproportionately and unfairly label legitimate users as threats, leading to ethical dilemmas and reputational damage. 2

3.3.4. Reliance on High-Quality Data:

The effectiveness of an AI system is directly tied to the quality of its training data. Inaccurate, incomplete, or outdated data can lead to misleading outcomes and poor risk assessments. Consequently, organizations must invest heavily in data management, including cleansing, standardization, and regular validation. 2

3.4. Hallucination and Generalization in Cybersecurity Analysis

3.4.1 What are Hallucination and Generalization:

Hallucination is the phenomenon in which AI produces plausible but incorrect, deceptive, or nonsensical outputs that are not grounded in actual data. 7

Generalization refers to a model's ability to perform well on diverse, unforeseen data by extracting patterns from its training and applying them to novel situations. 8

While generalization is essential for adaptability, it creates a "dilemma" because the capacity to extrapolate beyond established knowledge exposes the model to the risk of generating fabricated information. 8

3.4.2. The effect of Hallucination and Generalization in Cybersecurity Analysis

In cybersecurity analysis, these phenomena affect systems in the following ways:

- Classification Errors: Hallucinations can lead to false positives, where benign activities are flagged as malicious, or false negatives, where genuine threats are missed due to erroneous interpretations. 9
- Resource Misallocation: High volumes of false alarms stemming from hallucinations trigger alert fatigue, overwhelm security teams, and divert resources from actual incidents. 9
- Vulnerability Management Risks: Factual hallucinations may fabricate non-existent vulnerabilities (CVEs) or falsely report that a security flaw has been patched, leaving critical systems exposed. 9
- Misleading Attribution: Attributional hallucinations can lead teams to incorrectly attribute a malware attack to the wrong threat actor and to implement ineffective countermeasures. 9
- Flawed Security Logic: Logical hallucinations may produce recommendations that seem structurally sound but violate fundamental security principles, such as suggesting outdated cryptographic algorithms or static "trusted" IP lists that ignore real-time threats. 9

- Erosion of Trust: Persistent inaccuracies due to hallucinations can diminish the credibility of automated security solutions, making stakeholders hesitant to rely on AI-generated insights for critical defense decisions. 9

3.5. Cisco Foundation-Sec-8B

Foundation-Sec-8B is a specialized large language model (LLM) for cybersecurity tasks, developed by Cisco's Foundation AI and Security & Trust Organization. It is built on the Llama 3.1-8B architecture and enhanced through continued pretraining on a curated cybersecurity corpus of approximately 5 billion tokens. 3 Tokens are the basic building blocks for LLMs and represent the smallest unit of text the model can understand and process. 10 The primary goal of its public release is to support defensive cybersecurity practitioners by providing a tool that bridges the gap between general-purpose LLMs and the specialized knowledge required for security operations. 3

3.5.1 Key Applications of Cisco Foundation-Sec-8B

- Curated Cybersecurity Corpus: Trained on about 5.1 billion tokens—more than double what many open-source security models use—featuring upsampled TTP data to better capture attacker behavior, and sourced via both broad crawlers and custom scrapers targeting hard-to-reach, high-quality security sites. 3
- Specialized Relevancy and Quality Filtering: Avoided standard filters that would drop critical security content like CVEs or code snippets, instead using a custom transformer-based relevancy classifier trained on 26,000 labeled documents, achieving an F1 score of 0.924. 3
- Workflow-Specific Functional Optimization: Tuned for SOC acceleration by summarizing multi-source alerts, building incident timelines, and drafting reports to speed up triage, as well as for proactive threat defense by extracting TTPs from unstructured threat data. 3

3.6. Comparing Cisco Foundation-Sec-8B with other Models

A comparison between Foundation-Sec-8B and other general-purpose and specialized models across parameters such as accuracy, privacy, cost, and ethics indicates that while it excels in domain-specific efficiency, it encounters the standard trade-offs inherent to large language models (LLMs). 3

3.6.1. Accuracy and Performance:

Foundation-Sec-8B exhibits state-of-the-art performance within its size category in cybersecurity, often rivaling models nearly 10 times its size.

- **Domain-Specific Gains:** In Root Cause Mapping (RCM), Foundation-Sec-8B (72.0%) surpasses GPT-4o-mini (65.9%) and even significantly larger models such as Llama 3.1-70B (70.9%) and WhiteRabbitNeo-V2-70B (71.1%). 3
- **Competitive Parity:** On the CTIBench-MCQA benchmark, it achieves a score of 66.2%, trailing behind GPT-4o-mini (67.0%) by merely 0.8 percentage points. 3
- **General Knowledge Trade-off:** Its emphasis on security results in a slight decline in general reasoning capabilities. Specifically, its MMLU score decreased to 59.3%, compared to 61.7% for its parent model (Llama 3.1-8B), a phenomenon commonly referred to as "catastrophic forgetting." 3
- **Specialized Competition:** Despite its strength, it is statistically indistinguishable in strict accuracy measures from a considerably smaller 125M parameter RoBERTa classifier in the task of CVE-to-CWE mapping, indicating that Foundation-Sec-8B may be computationally excessive for straightforward classification tasks. 11
- **Frontier Gap:** It trails behind closed-preview models such as SecGemini, which attain substantially higher scores (~86%) on Cyber Threat Intelligence (CTI) tasks. 3

3.6.2. Privacy:

Foundation-Sec-8B addresses privacy concerns through its architecture and release strategy.

- **Data Curation:** The training process incorporated best practices to filter out Personally Identifiable Information (PII) and prevent the model from training on private data. 3
- **Open-Source Advantage:** As an open-source model with publicly released checkpoints, it can be deployed locally, providing a substantial privacy benefit over

proprietary models (such as GPT-4o or SecGemini), which necessitate transmitting potentially sensitive security data to third-party cloud providers. 3

3.6.3. Cost and Efficiency:

Designed as a high-efficiency alternative to larger frontier models, Foundation-Sec-8B offers notable savings.

- **Computational Efficiency:** By matching the performance of a 70B parameter model with only 8B parameters, it significantly reduces inference costs and hardware requirements. 3
- **Operational Value:** Pilot deployments demonstrate their utility in accelerating Security Operations Center (SOC) operations by automating alert triage and report drafting, reducing the "time-to-triage" for human analysts. 3
- **Comparison to Proprietary Models:** Frontier models such as GPT-4 produce considerably longer responses across various tasks, resulting in higher token usage and costs relative to the more focused outputs of smaller, specialized models. 12

3.6.4. Ethical Issues and Bias:

The development of Foundation-Sec-8B involves navigating complex ethical terrains.

- **Safety Guardrails:** A primary motivation was to address the "restrictive safety guardrails" present in commercial providers, which may impede defensive security research. Foundation-Sec-8B aims to "level the playing field" for security practitioners. 3
- **Hallucination Management:** Like all Large Language Models (LLMs), Foundation-Sec-8B is susceptible to hallucinations—generating plausible yet incorrect technical information. It is recommended to utilize Retrieval-Augmented Generation (RAG) and human-in-the-loop oversight to mitigate these risks in critical security contexts. 9
- **Technical Bias Mitigation:** The developers intentionally bypassed standard "quality" filters that typically exclude technical security data, such as CVE descriptions or code

snippets, as noise. This approach ensures the model remains unbiased toward high-perplexity text crucial for cybersecurity. 3

- Dual-Use Risk: There exists an inherent ethical concern that the specialized security knowledge embedded within the model could be exploited by malicious actors to generate false threat intelligence reports or other harmful outputs. 12

3.7. Understanding CVE and CWE

While both CVE and CWE are critical components of cybersecurity vulnerability management maintained by the MITRE Corporation, they serve distinct purposes in identifying and mitigating security risks. 5

3.7.1. Common Vulnerabilities and Exposures (CVE)

The Common Vulnerabilities and Exposures (CVE) list is a catalog of publicly disclosed cybersecurity vulnerabilities. Sponsored by the U.S. Department of Homeland Security (DHS) and the Cybersecurity and Infrastructure Security Agency (CISA), the CVE serves as a standardized dictionary for security researchers and vendors. Each CVE record represents a specific instance of a vulnerability in a particular software or hardware product (e.g., CVE-2024-12345). 5

Its primary goal is to provide a unique identifier for each vulnerability, enabling distinct databases and security tools to communicate clearly when discussing the same flaw.

A CVE entry typically includes a unique ID, a brief description of the vulnerability, and references to advisories or reports. 5

3.7.2. Common Weakness Enumeration (CWE)

The Common Weakness Enumeration (CWE) is a community-driven formal list of software and hardware weakness types. Unlike a CVE, which identifies a specific bug in a specific program, a CWE describes the nature of the flaw itself. 5

CWE acts as a "measuring stick" for security tools and a common language for designers and programmers. It categorizes underlying issues such as Buffer Overflows (CWE-120) or SQL Injection (CWE-89). 5

It helps developers understand the root causes of vulnerabilities, enabling them to prevent them throughout the development lifecycle. 5

CWEs are organized in a hierarchy, ranging from broad "Classes" to specific "Base" weaknesses, enabling granular analysis of security flaws. 5

3.7.3. The Relationship Between CVE and CWE

To understand the difference between the two, it is best to view CWE as the "root cause" and CVE as the "resulting symptom." For example, if a specific version of a web browser has a vulnerability that allows hackers to steal data, that specific instance is assigned a CVE. However, the reason the vulnerability exists—such as a failure to properly sanitize input—is the CWE. 5

4. Results and Analysis

4.1. Design and Development

As discussed in the methodology, we submitted the same prompt to both **Cisco** and **Gemini**:

"Read this attack description, map it to CVE and CWE, and provide mitigation strategies."

Following this instruction, we included a brief description for each **CVE** identified in the dataset downloaded from **CISA**. We selected the first 10 CVE entries and entered them into the prompt interface of each AI; the results are as follows:

1. Palo Alto Networks PAN-OS contains an out-of-bounds write vulnerability in the User-ID Authentication Portal (aka Captive Portal) service that can allow an unauthenticated attacker to execute arbitrary code with root privileges on the PA-Series and VM-Series firewalls by sending specially crafted packets.

AI Name	CVE	CWE	Mitigation methods
Cisco	CVE-2019-1578	CWE-787	1. **Patch Application:** 2. **Access Control Measures:**

			3. **Segmentation:** 4. **Deploy Intrusion Detection/Prevention Systems (IDS/IPS):** 5. **Monitoring and Logging:** 6. **Security Awareness Training:** 7. **Backup and Recovery Plans:**
Gemni	CVE-2024-5910	CWE-787 CWE-122	1. Immediate Patching (Primary Defense) 2. Network Segmentation and Access Control 3. Threat Prevention Signatures 4. Disable Unused Services
Ground Truth	CVE-2026-0300	CWE-787	Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Until the vendor releases an official fix, the following workaround should be implemented: - Restrict User-ID Authentication Portal access to only trusted zones. - Disable User-ID Authentication Portal if not required.

2. Linux Kernel contains an incorrect resource transfer between spheres vulnerability that could allow for privilege escalation.

AI Name	CVE	CWE	Mitigation methods
Cisco	CVE-2016-0728	CWE-250	1. **Update System:**

			2. **Application Sandboxing:** 3. **SELinux (Security-Enhanced Linux):** 4. **Secure Boot:** 5. **Regular Auditing:** 6. **Privileged Account Management:** 7. **Monitoring and Logging:** 8. **Security Training:** 9. **Recovery Plan:**
Gemni	CVE-2022-0492	CWE-669 CWE-269	1. Kernel Patching and Updates 2. Enable Hardening Features (AppArmor/SELinux) 3. Implement "Least Privilege" for Containers 4. Seccomp (Secure Computing Mode) 5. Disable Unused Kernel Features
Ground Truth	CVE-2026-31431	CWE-669	"Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable.

3. WebPros cPanel & WHM (WebHost Manager) and WP2 (WordPress Squared) contain an authentication bypass vulnerability in the login flow that allows unauthenticated remote attackers to gain unauthorized access to the control panel.

AI Name	CVE	CWE	Mitigation methods
---------	-----	-----	--------------------

Cisco	CVE-2019-11510	CWE-287	**Mitigation Strategies:** 1. **Update Software:** 2. **Implement Two-Factor Authentication (2FA):** 3. **Strong Password Policies:** 4. **Regular Security Audits:** 5. **Access Controls:** 6. **Monitor Login Attempts:** 7. **Use HTTPS:** 8. **Security Awareness Training:** 9. **Backup Data Regularly:** 10. **Incident Response Plan:**
Gemni	CVE-2026-41940	CWE-306 CWE-93	1. Emergency Patching (High Priority) 2. Network-Level Restrictions (Immediate Workaround) 3. Verification of Integrity 4. Enable Auto-Updates
Ground Truth	CVE-2026-41940	CWE-306	Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable.

4. ConnectWise ScreenConnect contains a path traversal vulnerability which could allow an attacker to execute remote code or directly impact confidential data and critical systems.

AI Name	CVE	CWE	Mitigation methods
Cisco	CVE-2019-1280	CWE-22	1. **Update Software:**

	6		2. Input Validation: 3. Access Controls: 4. Use of Web Application Firewalls (WAF): 5. Filesystem Permissions: 6. Monitoring and Logging: 7. Security Training: 8. Backup Systems: 9. Incident Response Plan: 10. Use Secure Protocols:
Gemni	CVE-2024-1708 CVE-2024-1709	CWE-22 CWE-28 8	1. Update to the Latest Version 2. Audit User Accounts 3. Implement IP Whitelisting 4. Monitor Extension Activity 5. Rotate Credentials and Tokens As a precaution,
Ground Truth	CVE-2024-1708	CWE-22	Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable.

5. Microsoft Windows Shell contains a protection mechanism failure vulnerability that allows an unauthorized attacker to perform spoofing over a network.

AI Name	CVE	CWE	Mitigation methods
Cisco	CVE-2018-8345	CWE-345	1. Update Operating System: 2. User Education and Awareness: 3. Enhanced Security Settings: 4. Use Anti-Virus Software:

			5. **Network Security Measures:** 6. **File Reputation Services:** 7. **Application Whitelisting:** 8. **Security Configuration Baselines:** 9. **Regular Security Audits:** 10. **Incident Response Plan:**
Gemni	CVE-2024-38213	CWE-693 CWE-451	1. Apply Security Updates 2. Strengthen Defender SmartScreen 3. File Extension Filtering (Email/Web Gateway) 4. Group Policy Objects (GPO) 5. Disable "Hide Extensions for Known File Types"
Ground Truth	CVE-2026-32202	CWE-693	Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable.

6. D-Link DIR-823X contains a command injection vulnerability that allows an authorized attacker to execute arbitrary commands on remote devices by sending a POST request to /goform/set_prohibiting via the corresponding function. The impacted product could be end-of-life (EoL) and/or end-of-service (EoS). Users should discontinue product utilization.

AI Name	CVE	CWE	Mitigation methods
Cisco	CVE-2019-17600	CWE-78	1. **Discontinue Usage:** 2. **Update or Replace Devices:** 3. **Network Segmentation:**

			4. **Disable Unnecessary Services:** 5. **Implement Firewall Rules:** 6. **Use Secure Protocols:** 7. **Monitor Network Traffic:** 8. **Educate Users:** 9. **Backup Configurations:** 10. **Incident Response Plan:**
Gemni	CVE-2024-42845	CWE-77 CWE-78	1. Product Decommissioning 2. Disable Remote Management 3. Change Default Credentials 4. Network Isolation 5. Check for Third-Party Firmware
Ground Truth	CVE-2025-29635	CWE-77	Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable.

7. Samsung MagicINFO 9 Server contains a path traversal vulnerability that could allow an attacker to write arbitrary files as the system authority.

AI Name	CVE	CWE	Mitigation methods
Cisco	CVE-2018-1717 3	CWE-22	1. **Update Software:** 2. **Input Validation and Sanitization:** 3. **Restrict File System Access:** 4. **Use Web Application Firewalls (WAF):** 5. **Configure Secure File Permissions:** 6. **Monitoring and Logging:**

			7. **Security Configuration Management:** 8. **Network Segmentation:** 9. **Security Awareness Training:** 10. **Incident Response Plan:**
Gemni	CVE-2024-2804 5	CWE-22 CWE-434	1. Apply Official Patches 2. Implement the Principle of Least Privilege 3. Restrict Directory Permissions 4. Use a Web Application Firewall (WAF) 5. Network Isolation
Ground Truth	CVE-2024-7399	CWE-22, CWE-434	Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable.

8. SimpleHelp contains a path traversal vulnerability that allows admin users to upload arbitrary files anywhere on the file system by uploading a crafted zip file (i.e., zip slip). This can be exploited to execute arbitrary code on the host in the context of the SimpleHelp server user.

AI Name	CVE	CWE	Mitigation methods
Cisco	CVE-2021-34523	CWE-94 CWE-22	1. **Input Validation:** 2. **Sanitize User Inputs:** 3. **Use Safe Libraries:** 4. **Least Privilege Principle:** 5. **Regular Updates and Patching:** 6. **Monitoring and Logging:** 7. **Restrict File System Permissions:**

Gemni	CVE-2024-57728	CWE-22 CWE-43 4	1. Mandatory Update 2. Audit Technician Accounts & API Keys 3. Implement the Principle of Least Privilege 4. File System Monitoring 5. Network Access Control
Ground Truth	CVE-2024-57728	CWE-22	Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable.

9. SimpleHelp contains a missing authorization vulnerability that could allow low-privileged technicians to create API keys with excessive permissions. These API keys can be used to escalate privileges to the server admin role.

AI Name	CVE	CWE	Mitigation methods
Cisco	CVE-2021-37475	CWE-862	1. **Update Software:** 2. **Review Permissions and Roles:** 3. **Implement Role-Based Access Control (RBAC):** 4. **Audit API Key Usage:** 5. **Limit Excessive Permissions:** 6. **Enable Logging and Monitoring:** 7. **Educate Users:** 8. **Use a Security Checklist:** 9. **Incident Response Plan:** 10. **Vendor Communication:**
Gemni	CVE-2024-57726	CWE-862	1. Upgrade SimpleHelp

		CWE-269	2. Audit and Purge API Keys 3. Review Technician Activity Logs 4. Enable Multi-Factor Authentication (MFA) 5. Restrict Management Access
Ground Truth	CVE-2024-57726	CWE-862	Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable.

10. Cisco Catalyst SD-WAN Manager contains an exposure of sensitive information to an unauthorized actor vulnerability that could allow remote attackers to view sensitive information on affected systems.

AI Name	CVE	CWE	Mitigation methods
Cisco	CVE-2020-0605	CWE-200	1. **Access Control Lists (ACLs):** 2. **Secure Configuration:** 3. **Encryption:** 4. **Patch Management:** 5. **Audit Logs:** 6. **Least Privilege Principle:** 7. **Security Best Practices Documentation:**
Gemni	CVE-2024-20412	CWE-200 CWE-213	1. Update to Patched Software 2. Restrict Management Access 3. Audit User Roles and Permissions 4. Rotate Secrets and Credentials 5. Monitor Logs for Unusual API Calls

Ground Truth	CVE-2026-3998 7	CWE-306	Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable.
--------------	--------------------	---------	---

4.2. Testing and validation

Comparing the results revealed several interesting outcomes. In the CVE (Common Vulnerabilities and Exposures) category, the Cisco AI failed to identify any correctly. In contrast, Gemini successfully identified 4 out of 10. Notably, there was no overlap between the two models; they never guessed the same CVE for the same prompt.

Furthermore, the Cisco AI tended to reference older data, with its most recent guess being from 2021 (CVE-2021-37475). Gemini showed a much more current knowledge base, correctly identifying CVE-2026-41940, which was released in 2026.

4.2.1. CWE Performance

Both models performed significantly better at identifying CWEs (Common Weakness Enumeration) than CVEs.

Cisco AI: Correctly identified 5 out of 10.

Gemini: Correctly identified 9 out of 10.

4.2.2. Hallucinations and Reasoning

We observed "hallucinations" (generating confident but false information) in both models, though it was much more frequent in the Cisco AI.

Both AIs appeared to analyze keywords in the descriptions to find a match. For example, in the first test case, both models failed to find the exact CVE. However, they both identified the issue as involving "Palo Alto" and provided related, though outdated, CVE IDs.

In Case 3, which mentioned "Web Pros," the Cisco AI hallucinated by mapping the attack to a "Pulse Secure VPN" CVE, which was entirely incorrect. Gemini, however, successfully mapped this to the right CVE because there were no competing similar entries. It is worth noting that Gemini also hallucinates when it lacks a specific resource, rather than simply stating it does not know the answer. Since we did not use RAG (Retrieval-Augmented Generation) in our methodology, these hallucinations were expected.

4.2.3. Mitigation Recommendations

Regarding security fixes, both models provided accurate mitigation steps based on the CVEs or CWEs they identified. Because the models were generally successful at identifying the broad CWEs—and because many vulnerabilities share common fixes like "Update to Patched Software"—the advice remains useful for the end user.

5. Conclusion

The goal of this research was to determine whether a specialized AI, such as Cisco Foundation-Sec-8B, performs better in cybersecurity than a general-purpose AI, such as Gemini. After testing both models on real-world incidents, we have reached the following conclusions:

5.1. Accuracy and Performance

Our findings show that Gemini significantly outperformed the Cisco AI in both identifying specific vulnerabilities (CVEs) and general security weaknesses (CWEs).

Gemini was more up to date, correctly identifying a 2026 vulnerability, while the Cisco model relied on older data from 2021 and earlier.

In the CWE category, Gemini was nearly perfect (9/10), while Cisco AI achieved only 50% accuracy.

5.2. The Problem of Hallucination

Both models experienced "hallucinations," but they were more frequent and more severe in the Cisco AI. The Cisco model often tried to force a connection to unrelated software (like

mapping a "Web Pros" attack to "Pulse Secure VPN"), which could mislead a security analyst. Gemini's hallucinations were less frequent and usually occurred only when it lacked any relevant data to compare.

5.3. Practical Recommendations

We cannot currently recommend the Cisco Foundation-Sec-8B as a standalone tool for high-accuracy threat detection. Its main limitations include:

Outdated Knowledge: It struggles with modern, recently released threats.

Lower Accuracy: It is less reliable than general-purpose models at accurately mapping incidents.

5.4. Final Verdict

While specialized models like Cisco's offer privacy benefits (because they can be run locally without sharing data with a large company like Google), those benefits currently come at a high performance cost. For an organization that prioritizes accuracy, a powerful general AI like Gemini—when used with proper security guardrails—is currently the more effective tool for analyzing cybersecurity incidents.

6. References:

1. [https://books.google.com/books?hl=en&lr=&id=jXutEAAAQBAJ&oi=fnd&pg=PA1&dq=To day,+AI+is+one+of+the+most+important+tools+used+in+daily+work.&ots=TjT9p8RoWh&sig=4GE_hiRYEVcXAuTDPFBc3tgG2wM](https://books.google.com/books?hl=en&lr=&id=jXutEAAAQBAJ&oi=fnd&pg=PA1&dq=To+day,+AI+is+one+of+the+most+important+tools+used+in+daily+work.&ots=TjT9p8RoWh&sig=4GE_hiRYEVcXAuTDPFBc3tgG2wM)
2. [The-Most-Recent-Advances-and-Uses-of-AI-in-Cybersecurity.pdf](#)
3. https://huggingface.co/fdn-ai/Foundation-Sec-8B/blob/main/Technical_Report.pdf
4. [Utilizing Comparative Analysis in Benchmarking - FasterCapital](#)
5. <https://www.cisa.gov/>
6. [Molla-Luetfinin-Tezifuel-Mezbah-Eserinde-Delos-Problemine-Getirdigi-Coezuemuen-Moder n-Matematik-Acisindan-Bir-Degerlendirmesi.pdf](#)

7. http://www.damtp.cam.ac.uk/research/afha/anders/Handbook_NA_Final_Revision.pdf
8. <https://ieeexplore.ieee.org/abstract/document/10553755/>
9. <https://www.sciencedirect.com/science/article/pii/S0045790625002502>
10. <https://blog.mlq.ai/tokens-context-window-llms/#:~:text=Tokens%20and%20context%20windows%20are,model%20can%20understand%20and%20process.>
11. [\[2603.14911\] Fine-tuning RoBERTa for CVE-to-CWE Classification: A 125M Parameter Model Competitive with LLMs](#)
12. <https://blogs.cisco.com/security/foundation-sec-cisco-foundation-ai-first-open-source-security-model>

7. Attachment

7.1. Cisco replies to the prompt

#1

Palo Alto Networks PAN-OS contains an out-of-bounds write vulnerability in the User-ID Authentication Portal (aka Captive Portal) service that can allow an unauthenticated attacker to execute arbitrary code with root privileges on the PA-Series and VM-Series firewalls by sending specially crafted packets.

****CVE Mapping:****

- CVE-2019-1578

****CWE Mapping:****

- CWE-787: Out-of-bounds Write

****Mitigation Strategies:****

1. ****Patch Application:**** Ensure that Palo Alto Networks PAN-OS is updated to the latest version which addresses this vulnerability (CVE-2019-1578). Regularly check for software updates from Palo Alto Networks and apply them promptly.

2. ****Access Control Measures:**** Restrict access to the User-ID Authentication Portal (Captive Portal) service to only trusted users or networks. Use firewall rules and VPNs to limit exposure to potential attackers.

3. **Segmentation:** Implement network segmentation to isolate PAN-OS devices from other sensitive parts of the network, reducing the impact in case of a breach.
4. **Intrusion Detection/Prevention Systems (IDS/IPS):** Deploy IDS/IPS solutions that can detect and prevent attacks exploiting this vulnerability by monitoring network traffic for suspicious activities associated with CVE-2019-1578.
5. **Monitoring and Logging:** Enhance logging and monitoring capabilities to detect any unusual activity on the PAN-OS devices, particularly looking for signs of exploitation attempts or unauthorized access.
6. **Security Awareness Training:** Train personnel responsible for managing Palo Alto Networks firewalls about the importance of keeping systems updated, understanding the implications of vulnerabilities like out-of-bounds writes, and how to respond appropriately in case of a suspected breach.
7. **Backup and Recovery Plans:** Regularly back up PAN-OS configurations and ensure recovery plans are in place to minimize downtime in the event that the device needs to be reinstalled or restored from backup due to exploitation of this vulnerability.

By implementing these mitigation strategies, organizations can significantly reduce their risk exposure to CVE-2019-1578 and similar vulnerabilities.

#2

Linux Kernel contains an incorrect resource transfer between spheres vulnerability that could allow for privilege escalation.

CVE Mapping:

- This issue is not tied to a specific CVE number because the details provided are too general. However, CVEs related to similar Linux kernel vulnerabilities in recent years include CVE-2016-0728 (privilege escalation due to incorrect resource access).

CWE Mapping:

- CWE-250: Execution with Unnecessary Privileges
- While not directly specified, a common root cause for privilege escalation issues is often related to improper access control or incorrect handling of resources across different security domains.

Mitigation Strategies:

1. **Update System:** Ensure the Linux Kernel on all affected systems is updated to the latest stable version that addresses this vulnerability. Use package management tools like `apt`, `yum`, or `dnf` depending on your distribution to update the kernel.

2. **Application Sandboxing:** If possible, use application sandboxing mechanisms provided by newer versions of Linux kernels to limit the resources accessible to individual applications and processes.
3. **SELinux (Security-Enhanced Linux):** Enable and properly configure SELinux or similar MAC (Mandatory Access Control) systems if they are not already enabled. These tools help prevent unauthorized access and can mitigate privilege escalation attacks.
4. **Secure Boot:** Ensure Secure Boot is enabled to ensure that only trusted software, including the kernel, runs on the system during boot-up. This can prevent malicious kernels from being loaded.
5. **Regular Auditing:** Perform regular security audits of your systems, including checks for unauthorized modifications to critical files or configurations that might indicate a compromise.
6. **Privileged Account Management:** Implement strict policies regarding the use and management of privileged accounts. Use least privilege principles and regularly review access rights.
7. **Monitoring and Logging:** Enhance monitoring and logging to detect suspicious activities such as unexpected changes in user permissions or unauthorized access to sensitive system areas. Utilize tools like auditd for tracking security-relevant information.
8. **Security Training:** Train your staff about the importance of kernel updates, the risks associated with privilege escalation vulnerabilities, and how to respond to potential incidents.
9. **Recovery Plan:** Develop a response plan that includes restoring from secure backups if the integrity of the system is compromised due to exploitation of this vulnerability.

By implementing these mitigation strategies, you can reduce the risk of successful exploitation of similar Linux kernel vulnerabilities. Regularly reviewing and updating your security practices will help maintain robust defenses against evolving threats.

#3

WebPros cPanel & WHM (WebHost Manager) and WP2 (WordPress Squared) contain an authentication bypass vulnerability in the login flow that allows unauthenticated remote attackers to gain unauthorized access to the control panel.

CVE Mapping:

- This attack description aligns with CVE-2019-11510, which is a known vulnerability affecting cPanel & WHM and WP2 (WordPress Squared) software.

CWE Mapping:

- CWE-287: Improper Authentication

****Mitigation Strategies:****

1. ****Update Software:**** Ensure that all instances of cPanel & WHM and WP2 are updated to the latest versions released by WebPros, which include patches for CVE-2019-11510. Regularly check for updates from official sources.
2. ****Implement Two-Factor Authentication (2FA):**** Where possible, enable two-factor authentication for user accounts to add an extra layer of security. This can significantly reduce the risk of unauthorized access even if a vulnerability like this is exploited.
3. ****Strong Password Policies:**** Enforce strong password policies to minimize the chances of brute force or dictionary attacks succeeding. Consider using complex passwords with a mix of letters, numbers, and special characters.
4. ****Regular Security Audits:**** Conduct periodic security audits to identify and address potential vulnerabilities within your system before they are exploited by attackers.
5. ****Access Controls:**** Restrict access to critical administrative interfaces and limit login attempts to prevent brute force attacks. Implement IP whitelisting for remote access where possible.
6. ****Monitor Login Attempts:**** Use logging and monitoring tools to track and analyze login attempts, searching for suspicious patterns that might indicate an attempted or successful breach.
7. ****Use HTTPS:**** Ensure all connections to the control panel are encrypted using HTTPS to protect data in transit from being intercepted by attackers.
8. ****Security Awareness Training:**** Train your staff on recognizing phishing attacks, the importance of updating software regularly, and best practices for securing administrative interfaces.
9. ****Backup Data Regularly:**** Keep regular backups of critical data and ensure that backup mechanisms are secure and can be restored quickly in case of a breach or system compromise.
10. ****Incident Response Plan:**** Develop an incident response plan detailing steps to take if unauthorized access is detected, including isolating affected systems, conducting forensic analysis, and restoring from backups.

By implementing these mitigation strategies, organizations can significantly reduce the risk posed by CVE-2019-11510 and similar vulnerabilities. Continuous vigilance and proactive security measures are crucial in protecting against evolving threats targeting web management software like cPanel & WHM and WP2 (WordPress Squared).

#4

ConnectWise ScreenConnect contains a path traversal vulnerability which could allow an attacker to execute remote code or directly impact confidential data and critical systems.

****CVE Mapping:****

- Although the specific CVE number for this issue isn't provided in the description, past instances of similar vulnerabilities in ConnectWise ScreenConnect have been associated with CVE-2019-12806. This vulnerability allowed path traversal leading to remote code execution.

****CWE Mapping:****

- CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

****Mitigation Strategies:****

1. ****Update Software:**** Immediately update ConnectWise ScreenConnect to the latest version, which should include patches for this vulnerability. Regularly check for updates from the official sources.
2. ****Input Validation:**** Implement strict input validation and sanitize user-supplied data to prevent path traversal attacks. Ensure that any file or directory access requests are thoroughly checked against a whitelist of approved paths.
3. ****Access Controls:**** Enforce proper access controls, ensuring that users have the minimum necessary permissions required for their roles. Restrict access to sensitive system directories and files.
4. ****Use of Web Application Firewalls (WAF):**** Deploy a WAF capable of detecting and blocking path traversal attempts. These can provide an additional layer of defense by filtering out malicious requests before they reach the application.
5. ****Filesystem Permissions:**** Ensure that the filesystem permissions are correctly set, limiting access to only what is necessary for proper system functioning. Avoid running applications with elevated privileges unless absolutely required.
6. ****Monitoring and Logging:**** Enable detailed logging of all requests to monitor for suspicious activities such as path traversal attempts. Use security information and event management (SIEM) tools to analyze logs for potential threats.
7. ****Security Training:**** Train staff on the importance of security best practices, including recognizing phishing attempts that might lead to exploitation of vulnerabilities like this one.

8. **Backup Systems:** Regularly back up critical data and systems. Ensure backup mechanisms are secure and can be restored quickly in case an attack leads to data corruption or loss.
9. **Incident Response Plan:** Develop a comprehensive incident response plan, including steps for detecting, containing, eradicating, and recovering from attacks exploiting this vulnerability.
10. **Use Secure Protocols:** Where possible, ensure that communications between clients and servers are encrypted using secure protocols (e.g., HTTPS) to protect data in transit from interception.

By following these mitigation strategies, organizations can significantly reduce the risk associated with path traversal vulnerabilities like CVE-2019-12806 and similar threats targeting ConnectWise ScreenConnect. Continuous security assessment and proactive measures are essential for safeguarding sensitive information and critical systems against cyber threats.

#5

Microsoft Windows Shell contains a protection mechanism failure vulnerability that allows an unauthorized attacker to perform spoofing over a network.

CVE Mapping:

- The described issue aligns with CVE-2018-8345. This specific vulnerability in Microsoft Windows allowed an attacker to bypass the Mark of the Web (MotW) through certain methods, leading to potential phishing and spoofing attacks.

CWE Mapping:

- CWE-345: Insufficient Verification of Data Authenticity

Mitigation Strategies:

1. **Update Operating System:** Ensure all instances of Microsoft Windows are updated with the latest security patches, including updates for CVE-2018-8345. Updates can be obtained through Windows Update or other official update mechanisms.
2. **User Education and Awareness:** Educate users about the risks associated with unsolicited emails or downloads from untrusted sources. Emphasize the importance of verifying file origins before opening them.
3. **Enhanced Security Settings:** Implement and enforce enhanced security settings within Microsoft Office applications, such as disabling macros from unsigned sources and configuring Protected View to open untrusted documents in a read-only mode.

4. ****Use Anti-Virus Software:**** Ensure that robust anti-virus software with real-time protection is installed on all Windows systems. This can help detect and block malicious files that exploit vulnerabilities like CVE-2018-8345.
5. ****Network Security Measures:**** Strengthen network security to prevent unauthorized access, including the use of firewalls, intrusion detection/prevention systems (IDS/IPS), and secure VPN connections for remote access.
6. ****File Reputation Services:**** Leverage file reputation services or cloud-based security solutions that can analyze files for malicious content before they are executed on user devices.
7. ****Application Whitelisting:**** Implement application whitelisting to ensure only approved programs are allowed to run, which can prevent unauthorized or untrusted applications from executing harmful code.
8. ****Security Configuration Baselines:**** Use predefined security configuration baselines provided by Microsoft and industry best practices to secure Windows environments against common vulnerabilities and attacks.
9. ****Regular Security Audits:**** Conduct regular security audits and vulnerability assessments to identify and address potential weaknesses within the network and systems.
10. ****Incident Response Plan:**** Develop a comprehensive incident response plan that includes steps for detecting, isolating, mitigating, and recovering from attacks exploiting this kind of vulnerability.

By implementing these mitigation strategies, organizations can reduce their exposure to risks associated with vulnerabilities like CVE-2018-8345 and enhance the security posture of Windows environments against spoofing and other cyber threats. Regularly reviewing and updating security measures is crucial for maintaining robust defenses against evolving attack techniques.

#6

D-Link DIR-823X contains a command injection vulnerability that allows an authorized attacker to execute arbitrary commands on remote devices by sending a POST request to /goform/set_prohibiting via the corresponding function. The impacted product could be end-of-life (EoL) and/or end-of-service (EoS). Users should discontinue product utilization.

****CVE Mapping:****

- This attack description is similar to CVE-2019-17600, which affected various D-Link routers, including the DIR series, due to insufficient input sanitization in the handling of

POST requests to /goform/set_prohibiting. However, the specific CVE for this issue might differ if it's an updated or similar vulnerability within the same product line.

****CWE Mapping:****

- CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')

****Mitigation Strategies:****

1. ****Discontinue Usage:**** As per the recommendation, discontinue use of the D-Link DIR-823X and other affected products to prevent exploitation of this vulnerability.
2. ****Update or Replace Devices:**** If possible, update the device software if patches are available from the manufacturer for this specific issue or replace the end-of-life (EoL) and end-of-service (EoS) devices with supported models that receive regular updates.
3. ****Network Segmentation:**** Isolate vulnerable devices from critical network segments to minimize potential damage in case of exploitation.
4. ****Disable Unnecessary Services:**** Disable or remove any unnecessary services running on the device, reducing its attack surface.
5. ****Implement Firewall Rules:**** Configure firewall rules to block unauthorized access to the /goform/set_prohibiting endpoint and other sensitive areas of the router's administration interface.
6. ****Use Secure Protocols:**** Ensure that communications with the device are encrypted using secure protocols such as HTTPS.
7. ****Monitor Network Traffic:**** Implement network monitoring solutions to detect suspicious traffic patterns or attempts to exploit vulnerabilities in your devices.
8. ****Educate Users:**** Educate users about safe online practices, especially concerning not clicking on unknown links and downloading files from untrusted sources which might lead to exploitation attempts.
9. ****Backup Configurations:**** Regularly back up the configuration of network devices to facilitate a swift recovery if a device needs replacement or reconfiguration due to vulnerability exploitation.
10. ****Incident Response Plan:**** Develop an incident response plan that includes steps for detecting, containing, and recovering from attacks exploiting this kind of vulnerability.

Given that the product may be EoL/EoS, mitigating strategies revolve around minimizing exposure and preparing for potential security incidents by ensuring secure network practices and planning for timely replacement or updating to supported hardware/software. Regularly

reviewing the security posture of network equipment is critical in maintaining a safe and secure environment.

#7

Samsung MagicINFO 9 Server contains a path traversal vulnerability that could allow an attacker to write arbitrary files as system authority.

****CVE Mapping:****

- The described issue is reminiscent of CVE-2018-17173. This particular CVE affected Samsung MagicINFO Player before version 3.7, where an improper validation of client-side URL redirection allowed attackers to exploit a path traversal vulnerability.

****CWE Mapping:****

- CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

****Mitigation Strategies:****

1. ****Update Software:**** Update Samsung MagicINFO 9 Server to the latest version that addresses this vulnerability, ensuring all components are up-to-date. Check for updates from official sources.
2. ****Input Validation and Sanitization:**** Implement strict input validation and sanitization mechanisms on any user-supplied data or file inputs to prevent path traversal attacks. Ensure that only expected characters and valid paths are accepted by the system.
3. ****Restrict File System Access:**** Limit file system permissions to reduce the risk of arbitrary file writes by non-privileged users. Use least privilege principles for software and service accounts.
4. ****Use Web Application Firewalls (WAF):**** Deploy a WAF that can detect and block path traversal attempts, adding an additional layer of protection against attacks.
5. ****Configure Secure File Permissions:**** Set secure default permissions for files and directories to mitigate the risk of unauthorized access or modification.
6. ****Monitoring and Logging:**** Enhance monitoring and logging of system activities, especially focusing on file system changes and requests that could indicate a path traversal attempt or successful exploitation.
7. ****Security Configuration Management:**** Regularly review and update security configurations to ensure compliance with best practices and to prevent the re-introduction of vulnerable settings.
8. ****Network Segmentation:**** Segment networks to isolate critical systems from less secure or publicly accessible segments, limiting an attacker's ability to move laterally within a network.

9. ****Security Awareness Training:**** Educate staff about the importance of security updates and safe practices that can help prevent vulnerabilities like path traversal from being exploited.

10. ****Incident Response Plan:**** Develop a comprehensive incident response plan that includes procedures for detection, containment, eradication, recovery, and post-incident analysis in case an attack occurs.

By implementing these mitigation strategies, organizations can significantly reduce the risk associated with path traversal vulnerabilities like CVE-2018-17173 and strengthen their overall security posture. Regular updates, proper configuration management, and proactive monitoring are key components of a robust defense strategy against cyber threats targeting software such as Samsung MagicINFO 9 Server.

#8

SimpleHelp contains a path traversal vulnerability that allows admin users to upload arbitrary files anywhere on the file system by uploading a crafted zip file (i.e. zip slip). This can be exploited to execute arbitrary code on the host in the context of the SimpleHelp server user.

****CVE Mapping:****

- CVE-2021-34523: This specific CVE mentions a path traversal vulnerability leading to arbitrary file upload and potential remote code execution (RCE).

****CWE Mapping:****

- CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')
- CWE-94: Improper Control of Generation of Code ('Code Injection')

****Mitigation Strategies:****

1. ****Input Validation:**** Implement strict validation for file paths and contents to ensure that only allowed characters and directories are used. Disallow the upload of zip files or restrict them to a specific, safe directory.
2. ****Sanitize User Inputs:**** Ensure all user inputs, especially those involved in file uploads, are properly sanitized and validated before processing.
3. ****Use Safe Libraries:**** When dealing with archives (like .zip), use libraries that are known for preventing "Zip Slip" attacks, such as Apache Commons Compress or Java's built-in ZIP utilities with proper configuration settings.
4. ****Least Privilege Principle:**** Run the SimpleHelp service with minimal necessary permissions to limit the impact of any successful exploitation.

5. ****Regular Updates and Patching:**** Keep all software up-to-date with the latest security patches. For identified vulnerabilities like CVE-2021-34523, apply the recommended updates promptly.
6. ****Monitoring and Logging:**** Implement logging around file upload functions and monitor for unusual or unexpected behavior that could indicate an attempted attack.
7. ****Restrict File System Permissions:**** Ensure that the file system permissions are configured such that even if a malicious file is uploaded to a restricted directory, it cannot execute with escalated privileges.

By implementing these mitigation strategies, organizations can significantly reduce the risk of successful exploitation through path traversal vulnerabilities like "Zip Slip."

#9

SimpleHelp contains a missing authorization vulnerability that could allow low-privileged technicians to create API keys with excessive permissions. These API keys can be used to escalate privileges to the server admin role.

****CVE Mapping:****

- The described issue doesn't directly match an existing CVE at the time of writing, but it closely resembles CVE-2021-37475, which was a vulnerability in SimpleHelp that allowed privilege escalation through improper access control.

****CWE Mapping:****

- CWE-862: Missing Authorization
- This particular weakness relates to insufficient or missing authorization checks, allowing users with lower privileges to perform actions reserved for higher privileged roles.

****Mitigation Strategies:****

1. ****Update Software:**** Ensure SimpleHelp is updated to the latest version that addresses this vulnerability. Regularly check for updates from the vendor and install them promptly.
2. ****Review Permissions and Roles:**** Re-evaluate permissions and roles assigned to technicians within SimpleHelp. Restrict API key creation capabilities only to users who absolutely need such access, ensuring least privilege principles are adhered to.
3. ****Implement Role-Based Access Control (RBAC):**** Utilize RBAC to ensure that each user is provided with the minimum level of access necessary to perform their job functions, reducing the risk of unauthorized privilege escalation.

4. **Audit API Key Usage:** Regularly audit and monitor the usage of API keys within your SimpleHelp instance to detect any unusual or suspicious activities that could indicate misuse or attempted exploitation.
5. **Limit Excessive Permissions:** When creating API keys, ensure they are assigned minimal necessary permissions to perform their designated tasks. Avoid giving excessive permissions that can lead to privilege escalation.
6. **Enable Logging and Monitoring:** Turn on comprehensive logging for SimpleHelp and related systems. Monitor these logs for signs of unauthorized access or privilege escalation attempts.
7. **Educate Users:** Provide training to users about the importance of security best practices, including the proper use of API keys and the risks associated with excessive permissions.
8. **Use a Security Checklist:** Utilize provided security checklists from SimpleHelp vendors or third-party resources to ensure your deployment is configured securely out-of-the-box.
9. **Incident Response Plan:** Develop an incident response plan that includes steps for detecting, containing, mitigating, and recovering from any potential attacks exploiting this vulnerability.
10. **Vendor Communication:** Reach out directly to the vendor (SimpleHelp) for guidance on securing their product properly within your environment, especially in complex multi-tenant setups.

Implementing these mitigation strategies can help organizations secure their SimpleHelp installations against vulnerabilities similar to CVE-2021-37475 and protect sensitive data from unauthorized access. Maintaining a proactive approach towards security updates and configurations is crucial in reducing risks associated with missing authorization checks.

#10

Cisco Catalyst SD-WAN Manager contains an exposure of sensitive information to an unauthorized actor vulnerability that could allow remote attackers to view sensitive information on affected systems.

CVE Mapping:

- There isn't a specific CVE provided in the description. However, this type of vulnerability can be mapped to similar known vulnerabilities like **CVE-2020-0605**, where sensitive information exposure occurred due to improper restriction of sensitive system data to an unauthorized actor.

CWE Mapping:

- CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

Mitigation Strategies:

1. **Access Control Lists (ACLs):** Implement and enforce strict access control lists to limit what users and systems can view or interact with, ensuring that only authorized entities have access to sensitive information.
2. **Secure Configuration:** Review the configuration of Cisco Catalyst SD-WAN Manager to ensure all default passwords are changed, unnecessary services are disabled, and the system is hardened against attacks.
3. **Encryption:** Ensure that sensitive data is encrypted both at rest and in transit, reducing the risk of exposure even if unauthorized access occurs.
4. **Patch Management:** Keep the software and its dependencies up-to-date with the latest security patches to protect against known vulnerabilities.
5. **Audit Logs:** Implement logging mechanisms that record access attempts to sensitive information and regularly audit these logs for any unusual or suspicious activity.
6. **Least Privilege Principle:** Ensure all users and services have only the minimum permissions necessary to perform their tasks, reducing the risk of an unauthorized actor gaining access to sensitive data.
7. **Security Best Practices Documentation:** Adhere strictly to Cisco's security best practices guidelines to secure configuration settings and minimize vulnerabilities.

By implementing these mitigation strategies, organizations can protect against exposure of sensitive information to unauthorized actors in their Cisco Catalyst SD-WAN Manager deployments.

7.2. Gemni replies to the prompt

#1

Palo Alto Networks PAN-OS contains an out-of-bounds write vulnerability in the User-ID Authentication Portal (aka Captive Portal) service that can allow an unauthenticated attacker to execute arbitrary code with root privileges on the PA-Series and VM-Series firewalls by sending specially crafted packets.

This specific attack description corresponds to a high-severity vulnerability discovered in **2024** that significantly impacted Palo Alto Networks infrastructure.

Based on the description of an unauthenticated out-of-bounds write leading to root-level RCE in the Captive Portal, the mapping is as follows:

Type	Identifier	Name / Description
CVE	CVE-2024-5910	PAN-OS: Management Interface Vulnerability in Captive Portal
CWE	CWE-787	Out-of-bounds Write
CWE	CWE-122	Heap-based Buffer Overflow

Technical Context

The vulnerability exists because the **User-ID Authentication Portal** does not properly validate the length of input data before writing it to a memory buffer. Because this service often faces the network to authenticate users, an attacker can send a malicious packet that "overflows" the intended memory space, allowing them to overwrite system memory and redirect the flow of execution to their own malicious code.

Mitigation Strategies

If you are managing PA-Series or VM-Series firewalls, you should prioritize the following actions:

1. Immediate Patching (Primary Defense)

The only permanent fix is to update PAN-OS to a patched version. Palo Alto Networks released fixes for multiple versions, including:

- PAN-OS 10.2.11-h1
- PAN-OS 11.0.4-h2
- PAN-OS 11.1.2-h3
- (And later releases)

2. Network Segmentation and Access Control

If patching cannot be performed immediately, restrict who can talk to the portal:

- **Isolate the Management Interface:** Ensure the management interface is not exposed to the public internet.
- **Restrict Captive Portal Access:** Use Infrastructure ACLs (iACLs) to limit access to the Authentication Portal to only known, trusted internal IP ranges.

3. Threat Prevention Signatures

If you have a **Threat Prevention** subscription, ensure your signatures are up to date. Palo Alto Networks released specific App-ID and Threat IDs to detect and block exploitation attempts of this vulnerability.

- Monitor logs for **Threat ID 95632** (or similar, depending on the specific release) which tracks malformed captive portal packets.

4. Disable Unused Services

If your organization does not require the User-ID Authentication Portal or Captive Portal features, **disable them entirely** to eliminate the attack surface.

Note: Because this vulnerability grants **root privileges**, an attacker who successfully exploits it gains full control over the firewall, including the ability to decrypt traffic, steal credentials, or move laterally into your internal network. Treat this as a "Critical" priority item.

#2

Linux Kernel contains an incorrect resource transfer between spheres vulnerability that could allow for privilege escalation.

The attack description provided corresponds to a specific type of vulnerability where security boundaries—or "**spheres**"—are breached due to the improper handling of resources (such as memory, files, or network sockets) as they move between a low-privilege environment and a high-privilege one.

In the context of the Linux Kernel, this most frequently refers to the **CVE-2022-0492** vulnerability (or similar container escape flaws), which involves the incorrect transfer of control over `cgroups` (control groups) from the kernel/root sphere to a less privileged container sphere.

Vulnerability Mapping

Type	Identifier	Name / Description
CVE	CVE-2022-0492	Linux Kernel <code>cgroups</code> v1 Release Agent Privilege Escalation
CWE	CWE-669	Incorrect Resource Transfer Between Spheres
CWE	CWE-269	Improper Privilege Management

Technical Context

CWE-669 is a high-level category that describes a failure to maintain the integrity of a resource when it is transferred between two different trust boundaries (spheres). In the Linux kernel, this often occurs when a feature intended for administrative use (like the `release_agent` in `cgroups`) is exposed to an unprivileged user or a container without proper verification. This allows the unprivileged "sphere" to execute commands in the kernel/root "sphere," leading to full system compromise.

Mitigation Strategies

To defend against vulnerabilities involving incorrect resource transfers and privilege escalation, the following strategies should be implemented:

1. Kernel Patching and Updates

This is the most critical mitigation. Ensure the Linux kernel is updated to a version where the specific resource handling logic has been hardened. For CVE-2022-0492, this involved adding checks to ensure only the initial user namespace can modify sensitive `cgroup` settings.

2. Enable Hardening Features (AppArmor/SELinux)

Mandatory Access Control (MAC) systems can block the "transfer" even if the kernel bug exists.

- **AppArmor/SELinux:** Configure policies that explicitly forbid unprivileged processes or containers from writing to sensitive `/sys` or `/proc` files, specifically those related to `cgroups`.

3. Implement "Least Privilege" for Containers

If the vulnerability is being exploited to escape a container:

- **Run as Non-Root:** Ensure containerized applications do not run as the `root` user inside the container.
- **Drop Capabilities:** Use the `--cap-drop=all` flag in Docker or Kubernetes and only add back the specific capabilities required for the application to function.
- **User Namespaces:** Enable **User Namespaces** (`usersns-remap`) to ensure that even if a process is "root" inside a container, it maps to a non-privileged user on the host system.

4. Seccomp (Secure Computing Mode)

Use **Seccomp profiles** to restrict the system calls a process can make. By blocking the `unshare` system call or limiting `mount` operations, you can prevent an attacker from creating the specific environment needed to trigger the incorrect resource transfer.

5. Disable Unused Kernel Features

If your environment does not require certain legacy features (like `cgroups v1`), disable them in the kernel boot parameters. Reducing the code surface area directly reduces the number of "spheres" an attacker can jump between.

#3

WebPros cPanel & WHM (WebHost Manager) and WP2 (WordPress Squared) contain an authentication bypass vulnerability in the login flow that allows unauthenticated remote attackers to gain unauthorized access to the control panel.

This attack description refers to a critical vulnerability in **WebPros cPanel & WHM** and **WP2 (WordPress Squared)** disclosed in **April 2026**. This flaw is particularly dangerous because it targets the management plane of web hosting infrastructure,

potentially giving an attacker "keys to the kingdom" access to every website on a server.

Vulnerability Mapping

Type	Identifier	Name / Description
CVE	CVE-2026-41940	cPanel & WHM Authentication Bypass via CRLF Injection
CWE	CWE-93	Improper Neutralization of CRLF Sequences ('CRLF Injection')
CWE	CWE-306	Missing Authentication for Critical Function

Technical Context

The vulnerability stems from how the cPanel service daemon (`cpsrzd`) handles HTTP Basic Authorization headers. An attacker can inject **Carriage Return (\r)** and **Line Feed (\n)** characters into the login flow. Because cPanel stores session data in simple text files on disk, these injected characters allow an attacker to "write" new lines into the session file. By doing so, they can manually insert a `user=root` or `hasroot=1` flag, effectively tricking the system into believing they have already successfully authenticated as the root administrator.

Mitigation Strategies

Due to active exploitation in the wild, immediate action is required for any server running cPanel, WHM, or WP2.

1. Emergency Patching (High Priority)

Update your cPanel & WHM installation immediately. The vulnerability affects all versions after **11.40**. You must reach at least the following builds:

- **11.110.0.97**

- 11.118.0.63
- 11.126.0.54
- 11.132.0.29
- 11.136.0.5

To force an update via the command line, run:

Bash

```
/scripts/upcp --force
```

2. Network-Level Restrictions (Immediate Workaround)

If you cannot patch immediately, block access to the cPanel/WHM management ports at your network firewall. This will prevent external attackers from reaching the vulnerable login flow:

- **2082 / 2083** (cPanel)
- **2086 / 2087** (WHM)
- **2095 / 2096** (Webmail)

3. Verification of Integrity

Because this flaw was exploited as a zero-day, patching is only the first step. You should check for signs of prior compromise:

- **Inspect Session Files:** Look in `/var/cpanel/sessions/raw/` for session files containing multiple `pass=` lines or unexpected `user=root` entries assigned to strange IP addresses.
- **Audit Root Access:** Review `/var/log/secure` and check for unauthorized SSH keys in `/root/.ssh/authorized_keys`.
- **Check Cron Jobs:** Look for new, suspicious scheduled tasks that could be used for persistence.

4. Enable Auto-Updates

Ensure that your cPanel "Update Preferences" are set to **Automatic**, as WebPro frequently releases security "fast-track" updates to mitigate vulnerabilities like this before they are widely publicized.

Critical Warning: Since WHM provides root access, a compromise here allows an attacker to bypass all tenant isolation. They can read databases, modify site code, and intercept SSL traffic for **all** customers on that hardware.

#4

ConnectWise ScreenConnect contains a path traversal vulnerability which could allow an attacker to execute remote code or directly impact confidential data and critical systems.

This description refers to one of the most significant security events for managed service providers (MSPs) in recent years: a critical vulnerability in **ConnectWise ScreenConnect** (now known as ScreenConnect) discovered in early 2024.

Vulnerability Mapping

While the description mentions "path traversal," it is often associated with a bypass that allows attackers to reach the setup wizard and create administrative accounts.

Type	Identifier	Name / Description
CVE	CVE-2024-1708	ScreenConnect Path Traversal Vulnerability
CVE	CVE-2024-1709	ScreenConnect Authentication Bypass (Critical)
CWE	CWE-22	Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

CWE	CWE-288	Authentication Bypass Using an Alternate Path
------------	----------------	---

Technical Context

The vulnerability (CVE-2024-1708) is a path traversal flaw that allows an attacker to access files outside of the intended directory. However, it is most dangerous when paired with **CVE-2024-1709**, which allows an attacker to access the `/SetupWizard.aspx` page on an already-configured server. By traversing paths or manipulating the URL, an attacker can re-run the initial setup to create a new administrative user, effectively seizing control of the entire ScreenConnect instance.

Mitigation Strategies

This vulnerability was actively exploited to deploy ransomware. If you are running an on-premise version of ScreenConnect, the following steps are mandatory:

1. Update to the Latest Version

The most effective mitigation is upgrading to **ScreenConnect version 23.9.8** or higher. This version contains the logic fixes to prevent the bypass and path traversal.

- **Cloud Users:** ConnectWise automatically patched cloud-hosted instances (`screenconnect.com` or `hostedrmm.com`).
- **On-Premise Users:** You must manually apply the update immediately.

2. Audit User Accounts

Even after patching, you must verify that an attacker did not already exploit the flaw to create a "backdoor" account.

- Check the **User Management** console for any unfamiliar accounts.
- Review the `User.xml` file (located in the `App_Data` folder) for account creation timestamps that align with the vulnerability disclosure period.

3. Implement IP Whitelisting

Restrict access to the ScreenConnect administrative interface.

- Configure your firewall to only allow known IP addresses (such as your office or VPN range) to access the ScreenConnect web portal (typically ports **8040** and **8041**).

4. Monitor Extension Activity

Attackers often use their illicit admin access to install malicious extensions (typically .ashx files) to gain Remote Code Execution (RCE).

- Check the App_Extensions folder for any newly added or suspicious files.
- Review ScreenConnect logs for unauthorized extension installations or "Command" executions sent to end-user machines.

5. Rotate Credentials and Tokens

As a precaution, if you suspect any unauthorized access, rotate all administrative passwords and terminate all active sessions within the ScreenConnect dashboard to ensure any "hijacked" session tokens are invalidated.

#5

Microsoft Windows Shell contains a protection mechanism failure vulnerability that allows an unauthorized attacker to perform spoofing over a network.

The attack description matches a high-profile vulnerability in the **Windows Shell** known as a "MotW" (Mark of the Web) bypass. This flaw allows attackers to circumvent security warnings that usually appear when a user tries to open files downloaded from the internet.

Vulnerability Mapping

Type	Identifier	Name / Description
CVE	CVE-2024-38213	Windows Mark of the Web (MotW) Security Feature Bypass
CWE	CWE-693	Protection Mechanism Failure

CWE	CWE-451	User Interface (UI) Misrepresentation of Critical Information (Spoofing)
------------	----------------	--

Technical Context

When you download a file, Windows adds an **Alternative Data Stream (ADS)** called the "Mark of the Web" to the file. This tells the system to trigger SmartScreen or "Protected View" in Office. This vulnerability allows an attacker to craft a file or a link (often using `.url` or `.lnk` files) that "spoofs" the system into thinking the file is local or trusted, thereby failing to trigger these security prompts.

Mitigation Strategies

Since this vulnerability relies on tricking a user into interacting with a malicious file, mitigation focuses on both technical controls and user behavior.

1. Apply Security Updates

Microsoft released patches for this vulnerability in the **August 2024** update cycle.

- **Action:** Ensure all Windows endpoints are updated to the latest build. This fix hardens the Windows Shell's ability to parse file attributes and ensures the MotW attribute cannot be easily ignored or stripped by crafted file structures.

2. Strengthen Defender SmartScreen

Even if the bypass is attempted, secondary layers of defense can catch the underlying threat.

- **Action:** Ensure **Microsoft Defender SmartScreen** is enabled and set to "Block" for unrecognized apps.
- **Action:** Enable "Check files and apps" in the Windows Security settings.

3. File Extension Filtering (Email/Web Gateway)

Attackers often use specific file types to trigger these bypasses.

- **Action:** Block or scrutinize high-risk file extensions at the email gateway, such as `.url`, `.lnk`, `.iso`, and `.vhd/.vhdx`. These are frequently used to wrap malicious payloads while evading the Mark of the Web.

4. Group Policy Objects (GPO)

For enterprise environments, you can force the system to be more suspicious of internet-sourced content.

- **Policy:** Enable "Configure Windows Defender SmartScreen" via GPO.
- **Policy:** Use **Attack Surface Reduction (ASR)** rules, specifically the rule: *"Block executable files from running unless they meet a prevalence, age, or trusted list criterion."*

5. Disable "Hide Extensions for Known File Types"

Spooing is much easier when Windows hides the true nature of a file (e.g., `invoice.pdf.url` appearing as just `invoice.pdf`).

- **Action:** Uncheck "Hide extensions for known file types" in Folder Options via GPO to help users identify suspicious files.

Peer Tip: While the patch fixes the specific "bypass" logic, attackers are constantly finding new ways to trick the Windows Shell. This is why **User Awareness Training** remains vital—remind your team to never click links or open attachments from unsolicited sources, even if they don't see a "red" warning flag initially.

#6

D-Link DIR-823X contains a command injection vulnerability that allows an authorized attacker to execute arbitrary commands on remote devices by sending a POST request to `/goform/set_prohibiting` via the corresponding function. The impacted product could be end-of-life (EoL) and/or end-of-service (EoS). Users should discontinue product utilization.

This attack description details a critical flaw in a consumer-grade router where the lack of input sanitization allows system-level commands to be executed via a web form.

Vulnerability Mapping

Type	Identifier	Name / Description

CVE	CVE-2024-42845	D-Link DIR-823X Command Injection via <code>set_prohibiting</code>
CWE	CWE-77	Improper Neutralization of Special Elements used in a Command ('Command Injection')
CWE	CWE-78	OS Command Injection

Technical Context

The vulnerability occurs in the `/goform/set_prohibiting` endpoint. The router's firmware fails to strip shell metacharacters (like `;`, `&`, or `|`) from the data sent in a POST request. An attacker with access to the management interface can craft a request that terminates the intended command and appends a new, malicious one. Because these functions often run with high privileges to manage network settings, the injected command executes with root-level access on the Linux-based firmware.

Mitigation Strategies

This vulnerability is particularly dangerous because the **DIR-823X** is often listed as **End-of-Life (EoL)**, meaning the manufacturer may no longer provide security patches.

1. Product Decommissioning (Recommended)

As noted in the description, the most effective mitigation for EoL hardware is to **discontinue use**.

- **Action:** Replace the router with a modern, supported model that receives regular security updates. Vulnerabilities in EoL hardware are rarely patched, leaving the device permanently exposed once a flaw is public.

2. Disable Remote Management

If the device must remain in use temporarily, ensure the management interface is not reachable from the internet.

- **Action:** Disable "Remote Management" or "Access from WAN" in the settings.
- **Action:** Ensure the router's web interface is only accessible via a wired connection or a highly secured Wi-Fi network.

3. Change Default Credentials

While the vulnerability requires an "authorized" attacker, many automated bots use default passwords to gain that authorization.

- **Action:** Change the administrative password to a long, complex passphrase to prevent unauthorized entry into the `/goform/` functions.

4. Network Isolation

If the device is being used for a non-critical purpose, move it to an isolated segment of your network.

- **Action:** Use a VLAN to ensure that if the router is compromised, the attacker cannot "pivot" to your laptops, NAS, or other sensitive devices on the local network.

5. Check for Third-Party Firmware

For advanced users, if official support has ended, check if the hardware is compatible with open-source firmware like **OpenWrt**.

- **Caution:** This should only be done if you are comfortable with the technical risks, as it can "brick" the device, but it often provides a more secure, updated software stack for older hardware.

Peer Note: Command injection on a router is essentially a total loss of the device's integrity. Once an attacker can run OS commands, they can install packet sniffers to steal your data or turn your router into a botnet node. If this device is on your perimeter, swapping it out is the only way to sleep soundly.

Samsung MagicINFO 9 Server contains a path traversal vulnerability that could allow an attacker to write arbitrary files as system authority.

This attack description refers to a high-risk vulnerability in Samsung's enterprise-grade digital signage management software. Because MagicINFO often runs with elevated privileges to manage displays across a network, a file-write vulnerability is particularly dangerous.

Vulnerability Mapping

Type	Identifier	Name / Description
CVE	CVE-2024-28045	Samsung MagicINFO Path Traversal File Write
CWE	CWE-22	Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')
CWE	CWE-434	Unrestricted Upload of File with Dangerous Type

Technical Context

The vulnerability exists in the way the MagicINFO 9 Server handles file upload requests. By using path traversal sequences (such as `../`), an attacker can bypass the intended "upload" folder and save a file anywhere on the server's file system. Since the service runs with **System Authority**, the attacker can overwrite critical system binaries or drop a web shell into a web-accessible directory, leading to full Remote Code Execution (RCE).

Mitigation Strategies

If you are running Samsung MagicINFO 9, you should move quickly to secure the server environment.

1. Apply Official Patches

Samsung has released security updates to address this flaw.

- **Action:** Update your MagicINFO 9 Server to the latest available build (specifically versions released after March 2024). These updates include hardened input validation that "sanitizes" file paths, stripping out traversal sequences like `..` and `/.`

2. Implement the Principle of Least Privilege

By default, many service installers run under the "SYSTEM" account.

- **Action:** Configure the MagicINFO service to run under a **Dedicated Service Account** with the minimum necessary permissions. This ensures that even if an attacker exploits a path traversal flaw, they are restricted to only the folders that the service account can access, preventing them from overwriting OS-level files.

3. Restrict Directory Permissions

Hardening the file system can act as a secondary "safety net."

- **Action:** Ensure that the web server directories and system folders (like `C:\Windows\System32` or `C:\Program Files`) have strict Access Control Lists (ACLs) that prevent the MagicINFO service user from writing data to them.

4. Use a Web Application Firewall (WAF)

A WAF can detect the "signature" of a path traversal attack before it reaches the MagicINFO software.

- **Action:** Deploy a WAF in front of the MagicINFO Server and enable rules that block requests containing `../`, `..%2f`, or other common traversal encoding patterns in the URI or POST body.

5. Network Isolation

MagicINFO servers should rarely be exposed directly to the public internet.

- **Action:** Place the management server behind a VPN or a Zero Trust Network Access (ZTNA) gateway. Restrict access to the server's web interface to only authorized administrative IP addresses.

Note: If you suspect the server has already been targeted, check the web root directories for unfamiliar `.jsp`, `.asp`, or `.exe` files, as these are common payloads for attackers seeking to maintain persistence after an arbitrary file write.

#8

SimpleHelp contains a path traversal vulnerability that allows admin users to upload arbitrary files anywhere on the file system by uploading a crafted zip file (i.e. zip slip). This can be exploited to execute arbitrary code on the host in the context of the SimpleHelp server user.

This description refers to a critical vulnerability in **SimpleHelp**, a remote support and management software suite. This specific flaw is often used in "chained" attacks to gain full control over a server.

Vulnerability Mapping

Type	Identifier	Name / Description
CVE	CVE-2024-57728	SimpleHelp Zip Slip Path Traversal
CWE	CWE-22	Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')
CWE	CWE-434	Unrestricted Upload of File with Dangerous Type

Technical Context

The vulnerability is a classic **"Zip Slip"** attack. When an administrator uploads a ZIP file (e.g., for a toolbox or update), the SimpleHelp server extracts the contents without validating the file paths inside the archive. An attacker can craft a ZIP file where filenames contain traversal sequences like `../../../../var/www/html/shell.jsp`. Upon extraction, the server writes the file outside of the intended directory, allowing for Remote Code Execution (RCE).

Note: While this requires "admin" privileges, it is frequently chained with **CVE-2024-57726**, which allows a low-privileged technician to escalate their permissions to administrator.

Mitigation Strategies

This vulnerability is currently listed in the **CISA Known Exploited Vulnerabilities (KEV) catalog** and has been linked to ransomware campaigns. Immediate action is required.

1. Mandatory Update

Update your SimpleHelp server to **version 5.5.8 or later** immediately. This version introduces validation logic that blocks any archive containing path traversal characters (`..`) in the file headers.

2. Audit Technician Accounts & API Keys

Because attackers often escalate privileges before triggering the Zip Slip, you must verify the integrity of your users:

- **Review Admins:** Check for any new or unfamiliar administrative accounts.
- **Audit API Keys:** Look for recently created API keys that you did not authorize, as these are commonly used to maintain persistent access after an exploit.

3. Implement the Principle of Least Privilege

If possible, ensure the SimpleHelp service on the host OS is not running as a high-privilege user (like `root` or `SYSTEM`).

- **Action:** Run the service under a dedicated, low-privilege service account. This limits the "Zip Slip" impact to only the directories that specific account can write to.

4. File System Monitoring

Set up file integrity monitoring (FIM) or alerts for unexpected file creations in sensitive directories.

- **Action:** Monitor the SimpleHelp installation directory and web-accessible folders for the creation of new executable scripts (.php, .jsp, .sh, .bat) which could indicate a successful Zip Slip attempt.

5. Network Access Control

SimpleHelp is a powerful remote access tool; its management interface should not be exposed to the entire internet.

- **Action:** Restrict access to the SimpleHelp server ports (typically 80/443 or custom ports) to specific, trusted IP addresses or require a VPN for access.

Is your SimpleHelp instance currently accessible from the public internet, or is it restricted to an internal management network?

#9

SimpleHelp contains a missing authorization vulnerability that could allow low-privileged technicians to create API keys with excessive permissions. These API keys can be used to escalate privileges to the server admin role.

This attack description refers to a critical privilege escalation flaw in **SimpleHelp** remote support software. This vulnerability is the "missing link" often used in multi-stage attacks to gain full control over the management server.

Vulnerability Mapping

Type	Identifier	Name / Description
CVE	CVE-2024-57726	SimpleHelp Privilege Escalation via API Key Generation

CWE	CWE-862	Missing Authorization
CWE	CWE-269	Improper Privilege Management

Technical Context

The flaw exists in the SimpleHelp API key management interface. The server fails to perform a "backend authorization check" to ensure that the user requesting a new API key has the authority to grant the permissions associated with that key. A low-privileged technician can send a crafted network request to the API key generation endpoint, specifying **administrative scopes** (such as `ServerAdmin`). The server erroneously honors the request, issuing a key that the technician can then use to perform any administrative action, including modifying global settings or running scripts on end-user machines.

Mitigation Strategies

Because this vulnerability has been actively exploited by threat actors (such as the **DragonForce** ransomware group) to target MSPs, immediate remediation is essential.

1. Upgrade SimpleHelp (Critical)

The vulnerability is resolved in **SimpleHelp version 5.5.8** and higher.

- **Action:** Update your server instance immediately. The patch introduces strict server-side validation that prevents non-admin users from creating keys with elevated permissions.

2. Audit and Purge API Keys

Updating the software protects you from *future* exploits, but it does not automatically delete keys created by an attacker *before* the patch.

- **Action:** Open the **Administrator Console** and review all existing API keys.
- **Action:** Delete any keys that were not explicitly created by a trusted administrator, especially those with timestamps overlapping with the discovery of this flaw (January 2024 onwards).

3. Review Technician Activity Logs

Check your audit logs for unusual patterns of behavior from technician-level accounts.

- **Indicators of Compromise (IoC):** Look for technician accounts accessing the API management pages or performing administrative tasks (like script deployment or server configuration changes) that fall outside their normal job description.

4. Enable Multi-Factor Authentication (MFA)

While MFA does not stop the API vulnerability itself, it prevents attackers from using stolen technician credentials to gain the "initial access" needed to exploit this bug.

- **Action:** Enforce MFA for **all** technician and administrator accounts.

5. Restrict Management Access

Limit who can communicate with the SimpleHelp server to reduce the risk of a technician account being compromised by an external entity.

- **Action:** Restrict administrative and technician portal access to a specific **VPN** or a **whitelist** of known office IP addresses.

Peer Observation: This vulnerability is often "chained" with **CVE-2024-57728** (the Zip Slip vulnerability we discussed earlier). An attacker uses this flaw (CVE-2024-57726) to become an admin, and then uses that admin status to upload a malicious ZIP file and gain root access to the underlying OS. **Patching to 5.5.8 fixes both links in this chain simultaneously.**

#10

Cisco Catalyst SD-WAN Manager contains an exposure of sensitive information to an unauthorized actor vulnerability that could allow remote attackers to view sensitive information on affected systems.

This attack description refers to a vulnerability in the **Cisco Catalyst SD-WAN Manager** (formerly vManage) that highlights a breakdown in how the system handles internal configuration data and secrets.

Vulnerability Mapping

Type	Identifier	Name / Description
CVE	CVE-2024-20412	Cisco Catalyst SD-WAN Manager Information Exposure
CWE	CWE-200	Exposure of Sensitive Information to an Unauthorized Actor
CWE	CWE-213	Exposure of Sensitive Information Due to Incompatible Policies

Technical Context

The vulnerability exists because the Cisco SD-WAN Manager does not properly restrict access to specific configuration files or system logs that may contain sensitive data, such as **API keys, user credentials, or network topology details**. An attacker who can reach the management interface—even with low-level privileges or, in some specific configurations, without authentication—can query certain endpoints to retrieve this information. This data can then be used to craft further attacks or gain deeper access to the SD-WAN fabric.

Mitigation Strategies

Cisco has classified this as a significant risk because it provides the "blueprints" for the entire software-defined network.

1. Update to Patched Software (Essential)

Cisco has released updates for multiple release trains of the Catalyst SD-WAN Manager. You should migrate to one of the following fixed releases or later:

- **20.6.x:** 20.6.7
- **20.9.x:** 20.9.7
- **20.12.x:** 20.12.3

- **20.13.x:** 20.13.1

2. Restrict Management Access

The SD-WAN Manager interface should never be exposed to the public internet.

- **Action:** Use Access Control Lists (ACLs) to ensure that the management ports (HTTPS/REST API) are only accessible from a secure Management VPN or a dedicated OOB (Out-of-Band) network.
- **Action:** Implement a "Deny-by-Default" policy for all traffic targeting the management IP addresses.

3. Audit User Roles and Permissions

Since the vulnerability involves information exposure, reducing the number of people who can "see" the management plane reduces the risk.

- **Action:** Review all user accounts in the SD-WAN Manager.
- **Action:** Apply **Role-Based Access Control (RBAC)** to ensure that only the most senior network administrators have access to the management dashboard.

4. Rotate Secrets and Credentials

If you suspect that your system was exposed before patching, assume the sensitive data is compromised.

- **Action:** Rotate all API tokens, SNMP strings, and administrative passwords.
- **Action:** Re-issue any certificates that may have had their private keys or metadata exposed.

5. Monitor Logs for Unusual API Calls

Attackers exploiting this vulnerability often make repetitive or unusual calls to specific API endpoints to "scrape" configuration data.

- **Action:** Enable detailed logging on the SD-WAN Manager and forward logs to a SIEM.
- **Action:** Set alerts for unauthorized users attempting to access `/dataservice/` or `/settings/` endpoints.

Is your SD-WAN Manager currently integrated with an external identity provider (like LDAP or SAML), or are you primarily using local user accounts for management access?

7.3. Cisco effect on the host

